

Materia

Seguridad en el Desarrollo de Aplicaciones

Nombre

Ricardo Porras Reyes

Matricula

2024171008

Grupo

IDSG17

Profesor

Gerardo Ramírez Villarreal

Dashboard

Usuario: user1

Email: user@test.com

Balance: 500.00

[Cerrar sesión](#)

Dashboard

Usuario: admin

Email: admin@test.com

Balance: 1000.00

[Cerrar sesión](#)

Login

Usuario/contraseña inválido

```
public IActionResult Login(string username, string password)
{
    if (username == "admin" && password == "admin")
    {
        HttpContext.Session.SetString("User", username);
        HttpContext.Session.SetInt32("UserId", 1);

        return RedirectToAction("Dashboard");
    }

    string query =
        "SELECT * FROM Users WHERE Username = '" +
        username +
        "' AND Password = '" +
        password +
        "'";

    var user = _db.Users
        .FromSqlRaw(query)
        .FirstOrDefault();
}
```

Caso	Entrada	Resultado
Usuario válido	user1 / 123456	Acceso permitido
Usuario válido	user2 / password	Acceso permitido
Credencial predeterminada	admin / admin	Acceso permitido
Credencial incorrecta	usuario / incorrecto	Acceso denegado

Hallazgos identificados

Existencia de credenciales predeterminadas (admin/admin), lo que facilita accesos no autorizados si no son modificadas.

Contraseñas almacenadas en texto plano dentro de la base de datos.

Construcción de consultas mediante concatenación de cadenas, lo que representa un riesgo de SQL Injection.

Ausencia de mecanismos de protección como hash de contraseñas, bloqueo de cuentas o autenticación multifactor.

Recomendaciones

Utilizar consultas parametrizadas.

Almacenar contraseñas con hash seguro (bcrypt o PBKDF2).

Eliminar credenciales predeterminadas.

Implementar políticas de complejidad y expiración de contraseñas.

Incorporar controles de sesión más robustos.